

# Тестирование безопасности сайта ЧистоДома

Практическая работа 9 · отчёт по локальным проверкам

|               |                                                                            |
|---------------|----------------------------------------------------------------------------|
| Исполнитель   | Аньшин Сергей, группа ИСП-406                                              |
| Объект        | Учебный сайт ЧистоДома; локальный адрес http://127.0.0.1:8000              |
| Дата проверки | 7 октября 2026 года                                                        |
| Среда         | Windows 11, PostgreSQL 18, Docker Desktop; сканеры в отдельных контейнерах |

## Цель и границы проверки

Цель работы - проверить контейнерную инфраструктуру и доступное без входа веб-приложение, сравнить результаты Nikto и OWASP ZAP, применить Nmap к собственному серверу и изучить возможности других инструментов.

Сайт запущен локально на порту 8000. Для контейнеров сканеров использовалось имя host.docker.internal. Проверки выполнялись только на этом учебном окружении. Авторизованные функции, другие порты и внешние узлы в область проверки не входили.

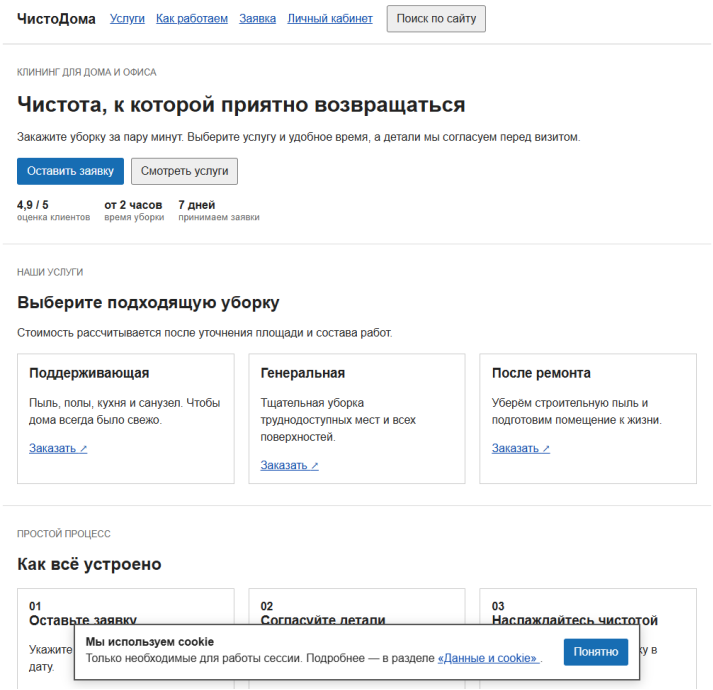


Рисунок 1 - главная страница проверяемого сайта

## 1 Проверка контейнерной инфраструктуры

Trivy 0.75.0 проверил два актуальных образа PostgreSQL 16 с фильтром HIGH и CRITICAL. Первый образ соответствует значению в compose.yml проекта; второй проверен как кандидат для уменьшения числа находок в системных пакетах. Сканирование образа не является сканированием установленной Windows или работающей локальной PostgreSQL 18.

| Образ и компонент                 | HIGH | CRITICAL |
|-----------------------------------|------|----------|
| postgres:16, Debian 13.7          | 61   | 1        |
| gosu в postgres:16                | 21   | 1        |
| postgres:16-alpine, Alpine 3.24.2 | 0    | 0        |
| gosu в postgres:16-alpine         | 21   | 1        |

Переход с проверенного Debian-образа на Alpine-кандидат уменьшает число находок в пакетах ОС с 62 до 0, однако 22 находки в gosu остаются. Это сравнение образов, а не подтверждение обновления работающей базы. Перед заменой образа в проекте нужны проверка расширений, кодировок, резервного копирования и запуска с данными приложения.

```
Trivy — сравнение образов PostgreSQL 16

Trivy - результаты сканирования образов PostgreSQL 16
Дата: 2026-10-07
Фильтр: HIGH, CRITICAL

trivy-postgres16.json
postgres:16 (debian 13.7)
HIGH: 61 CRITICAL: 1
usr/local/bin/gosu
HIGH: 21 CRITICAL: 1

trivy-postgres16-alpine.json
postgres:16-alpine (alpine 3.24.2)
HIGH: 0 CRITICAL: 0
usr/local/bin/gosu
HIGH: 21 CRITICAL: 1

Исходные JSON-файлы сохранены рядом с этой сводкой.
Сканирование выполнено на локальных Docker-образах.
```

Рисунок 2 - сводка из сохранённых JSON-результатов Trivy

Исходные результаты: trivy-postgres16.json и trivy-postgres16-alpine.json. Повторная проверка выполнена для альтернативного образа той же основной версии PostgreSQL.

## 2 Сканирование сайта Nikto

Nikto 2.5.0 проверил HTTP-сервис на порту 8000. Время прохода ограничено 45 секундами, поэтому результат неполный. Сканер сообщил о трёх пунктах: устаревающем X-Frame-Options, отсутствии HSTS и разрешённых методах GET и POST.

### Nikto — локальное сканирование

```
- Nikto v2.5.0
-----
+ Target IP:      192.168.65.254
+ Target Hostname: host.docker.internal
+ Target Port:    8000
+ Start Time:     2026-10-07 17:22:51 (GMT0)
-----
+ Server: BaseHTTP/0.6 Python/3.14.7
+ /:X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive instead. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ OPTIONS: Allowed HTTP Methods: GET, POST .
+ ERROR: Host maximum execution time of 45 seconds reached
+ Scan terminated: 0 error(s) and 3 item(s) reported on remote host
+ End Time:      2026-10-07 17:23:37 (GMT0) (46 seconds)
-----
+ 1 host(s) tested
```

Рисунок 3 - сохранённый вывод Nikto с адресом цели и находками

Для локального HTTP отсутствие HSTS ожидаемо: браузер применяет этот заголовок при HTTPS. Заголовок X-Frame-Options дублируется действующей политикой CSP с frame-ancestors 'none'. Список GET и POST соответствует назначению приложения. Ни один из этих пунктов сам по себе не доказывает эксплуатацию уязвимости.

Ограничение: Nikto завершил проход по лимиту времени, поэтому отсутствие иных находок нельзя считать доказательством безопасности всех маршрутов.

### 3 Сканирование сайта OWASP ZAP

OWASP ZAP 2.17.0 выполнил baseline-сканирование: обход доступных без входа страниц и пассивные проверки ответов. Получены 0 высоких, 1 среднее, 3 низких и 4 информационных предупреждения.



Site: <http://host.docker.internal:8000>

Generated on Wed, 7 Oct 2026 17:19:51

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

#### Summary of Alerts

| Risk Level      | Number of Alerts |
|-----------------|------------------|
| High            | 0                |
| Medium          | 1                |
| Low             | 3                |
| Informational   | 4                |
| False Positives | 0                |

#### Insights

| Level | Reason        | Site                                                                            | Description                                                | Statistic |
|-------|---------------|---------------------------------------------------------------------------------|------------------------------------------------------------|-----------|
| Info  | Informational | <a href="http://host.docker.internal:8000">http://host.docker.internal:8000</a> | Percentage of responses with status code 2xx               | 83 %      |
| Info  | Informational | <a href="http://host.docker.internal:8000">http://host.docker.internal:8000</a> | Percentage of responses with status code 4xx               | 16 %      |
| Info  | Informational | <a href="http://host.docker.internal:8000">http://host.docker.internal:8000</a> | Percentage of endpoints with content type application/json | 20 %      |
| Info  | Informational | <a href="http://host.docker.internal:8000">http://host.docker.internal:8000</a> | Percentage of endpoints with content type text/css         | 10 %      |
| Info  | Informational | <a href="http://host.docker.internal:8000">http://host.docker.internal:8000</a> | Percentage of endpoints with content type text/html        | 60 %      |
| Info  | Informational | <a href="http://host.docker.internal:8000">http://host.docker.internal:8000</a> | Percentage of endpoints with content type text/javascript  | 10 %      |
| Info  | Informational | <a href="http://host.docker.internal:8000">http://host.docker.internal:8000</a> | Percentage of endpoints with method GET                    | 100 %     |
| Info  | Informational | <a href="http://host.docker.internal:8000">http://host.docker.internal:8000</a> | Count of total endpoints                                   | 10        |

#### Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

#### Alerts

| Name                                                                   | Risk Level | Number of Instances |
|------------------------------------------------------------------------|------------|---------------------|
| <a href="#">Absence of Anti-CSRF Tokens</a>                            | Medium     | Systemic            |
| <a href="#">Cross-Origin-Embedder-Policy Header Missing or Invalid</a> | Low        | 5                   |

Рисунок 4 - начало автоматически сформированного HTML-отчёта ZAP

| Предупреждение           | Проверка и оценка                                                                                                          |
|--------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Нет anti-CSRF token      | В сервере есть проверка Origin; POST с чужим Origin вернул 403. Предупреждение требует ручной оценки, токена в формах нет. |
| Нет COEP и CORP          | Низкий уровень; заголовки нужны после оценки сценариев изоляции и встраивания ресурсов.                                    |
| Server раскрывает версию | Подтверждено ответом BaseHTTP/0.6 Python/3.14.7; версию лучше не показывать клиенту.                                       |

## 4 Сравнение Nikto и ZAP

| Критерий         | Nikto                                                       | ZAP baseline                                       |
|------------------|-------------------------------------------------------------|----------------------------------------------------|
| Подход           | Проверка типовых настроек и известных признаков веб-сервера | Обход страниц и пассивный анализ HTTP-ответов      |
| Итог             | 3 пункта за ограниченный 45-секундный проход                | 0 high, 1 medium, 3 low, 4 info                    |
| Общее наблюдение | Версия сервера видна в ответе                               | Отдельное предупреждение о раскрытии версии Server |
| Отличие          | Указал HSTS на HTTP                                         | Указал формы без anti-CSRF token                   |

Результаты не следует складывать как независимые уязвимости: два сканера по-разному оценивают одни и те же ответы. ZAP не проверял вход под учётной записью и не выполнял активную атаку; Nikto также не завершил полный набор тестов.

## 5 Применение Nmap к собственному серверу

Команда Nmap 7.98 ограничена одним адресом и одним портом: `nmap -sT -sV -Pn -p 8000 host.docker.internal`. Порт 8000/tcp определён как открытый HTTP-сервис BaseHTTPServer 0.6 на Python 3.14.7.

### Nmap — проверка порта 8000

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-07 17:24 +0000
Nmap scan report for host.docker.internal (192.168.65.254)
Host is up (0.0022s latency).
Other addresses for host.docker.internal (not scanned): fdc4:f303:9324::254

PORT      STATE SERVICE VERSION
8000/tcp  open  http    BaseHTTPServer 0.6 (Python 3.14.7)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.70 seconds
```

Рисунок 5 - результат Nmap по учебному серверу

## 6 Назначение инструментов

| Инструмент    | Назначение и применение в этой работе                                                                                                     |
|---------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| Metasploit    | Платформа с модулями для проверки и эксплуатации известных уязвимостей. Изучена документация; эксплуатация на сайте не проводилась.       |
| Netcat / Ncat | Утилита для TCP/UDP-соединений в режимах подключения и прослушивания. Изучена; вместо неё для проверки сервиса применён Nmap.             |
| Nmap          | Обнаруживает доступные порты и версии сервисов. Реально проверен порт 8000 локального сайта.                                              |
| sqlmap        | Автоматизирует выявление SQL-инъекций. На сайте в этом проходе не запускался; без выбранной точки ввода вывод о SQL-инъекциях невозможен. |

## 7 MITRE Caldera

Caldera предназначена для эмуляции действий атакующего: агент выполняет наборы abilities в рамках операции и передаёт результаты серверу. Инструмент полезен для проверки обнаружения и реагирования в изолированной лаборатории. Отдельная виртуальная машина и агент для этой работы не развёрнуты; операция и атака через Caldera не проводились. Скриншота или результата Caldera в отчёте нет.

## Вывод

Локальный сайт доступен на порту 8000. Nikto и ZAP не подтвердили критическую уязвимость в анонимной части, но выявили раскрытие версии сервера и ряд заголовков и форм, требующих оценки. Trivy показал снижение находок в пакетах ОС у Alpine-кандидата, при сохранении проблем компонента gosu. Следующие шаги: убрать версию из Server, проверить CSRF на авторизованных действиях, запустить ZAP после входа и повторить сканирование инфраструктуры после фактического обновления.

## Источники

1. Задание на тестирование безопасности, предоставленное преподавателем.
2. Документация Trivy: <https://trivy.dev/docs/>
3. Документация Nikto: <https://github.com/sullo/nikto/wiki>
4. Документация OWASP ZAP: <https://www.zaproxy.org/docs/docker/>
5. Руководство Nmap: <https://nmap.org/book/man.html>
6. Документация MITRE Caldera: <https://caldera.readthedocs.io/>
7. Документация Metasploit и sqlmap: <https://docs.metasploit.com/>; <https://github.com/sqlmapproject/sqlmap/wiki/usage>